

شركة دايموند لوساطة التأمين
سياسة إدارة الوصول
مايو 2025

الاسم المسجل: شركة الوثيقة الماسية لوساطة التأمين
المركز الرئيسي: طريق الثمامة، الربيع، الرياض
مسؤول المستند: مدير إدارة الجودة والتطوير

المحتويات	
1	المقدمة
2	الهدف من السياسة
3	تعريف
4	نطاق تطبيق السياسة
5	القطاعات والإدارات ذات العلاقة
6	الكيانات ذات العلاقة
7	قواعد عامة
8	مسؤولية السياسة
9	التعاميم والتعليمات ذات العلاقة
10	حفظ السياسة
11	مخالفة السياسة



إدارة الجودة والتطوير Quality & Development Management

المادة (1): يحتوي هذا المستند على المعلومات المتعلقة بشركة الوثيقة الماسية (دايموند) ولا يجوز استخدام أو نسخ هذا المستند أو المعلومات التي يحتوي عليها كاملة أو جزءا منها أو كشفه إلى الغير ما لم تقدم شركة الوثيقة الماسية (دايموند) موافقتها الكتابية على ذلك. لا يجوز تعديل أو حذف هذا التصريح المقيد في أي حالة من هذا المستند.

المادة (2): في حال وجود اختلاف بين النص العربي والإنجليزي فإن السيادة تكون للنص العربي.



Internal

DO NOT COPY

معلومات السياسة				
سياسة إدارة الوصول			عنوان السياسة	
مُستخدمة			حالة السياسة	
برنامج أمن المعلومات - مسؤوليات سياسة الأمن السيبراني - سياسة تطوير وقبول أنظمة - سياسة إدارة شبكة			عنوان السياسة السابقة	
لا يوجد			تاريخ السياسة السابقة	
1ITM0012			رقم المستند	
بعد مُرور سنتين من تاريخ اعتماد السياسة أو عند الضرورة			تاريخ المراجعة القادمة	
إدارة تقنية المعلومات			مالك السياسة	
إدارة الجودة والتطوير			إعدت بواسطة	
مسؤولو القطاعات والإدارات الذين راجعوا السياسة ووافقوا عليها				
التوقيع	التاريخ	الأسم	الوظيفة	الإدارة
	29/07/2025	تركي عبد الله العبدلي	مدير إدارة الالتزام والامتثال	الإدارة الرقابية
	29/07/2025	شادن سلطان العتيبي	مدير إدارة الجودة والتطوير	رئيس مراجعة السياسات
اعتماد السياسة				
	29/07/2025	بدر سعد الشايع	العضو المنتدب	الإدارة العليا



إدارة الجودة والتطوير
Quality & Development Management

1. المقدمة:

1.1 تُعد سياسة إدارة الوصول جزءاً أساسياً في إطار الحوكمة التقنية، وتهدف إلى ضبط وتوثيق عملية منح وإدارة الصلاحيات للمستخدمين داخل الأنظمة التقنية في الشركة. وتوفر هذه السياسة الإطار التنظيمي الذي يضمن الاستخدام الآمن والمنضبط لحسابات المستخدمين، ويمنع الوصول غير المصرح به أو الاستغلال الخاطئ للصلاحيات داخل البيئة الرقمية للشركة.

2. الهدف من السياسة:

- 2.1 تتفق شركة الوثيقة الماسية لوساطة التأمين (ويشار إليها فيما يلي بـ "دايموند") في أن الهدف من هذه السياسة هو تنظيم إجراءات منح وتعديل وإلغاء صلاحيات الوصول إلى الأنظمة التقنية التابعة للشركة، وذلك بما يضمن الالتزام بتطبيق مبدأ أقل صلاحية (Least Privilege) وفصل المهام (Segregation of Duties).
- 2.2 تقليل المخاطر الناتجة عن إساءة استخدام الحسابات أو الوصول غير المصرح به، مع توثيق دورة حياة الصلاحيات بدءاً من إنشائها وحتى إلغائها. وتأتي هذه السياسة أيضاً امتثالاً للتعليمات التنظيمية الصادرة عن الجهات الرقابية المختصة في المملكة العربية السعودية.

3. تعاريف:

- 3.1 داييموند: شركة الوثيقة الماسية لوساطة التأمين.
- 3.2 المستخدم (User): أي موظف، متدرب، استشاري، مورد، أو طرف ثالث مُخول باستخدام أحد أنظمة الشركة التقنية.
- 3.3 الحساب (Account): معرف إلكتروني فريد يُستخدم للوصول إلى نظام معين ويُربط باسم مستخدم وصلاحيات محددة.
- 3.4 الصلاحية (Privilege): مستوى التحكم أو الوظائف التي يُسمح للمستخدم بتنفيذها داخل النظام (مثل: عرض، تعديل، حذف، اعتماد).
- 3.5 الوصول (Access): عملية دخول المستخدم إلى أحد أنظمة الشركة باستخدام بيانات الدخول المعتمدة لأداء المهام.
- 3.6 الصلاحية المؤقتة (Temporary Access): صلاحية تُمنح لمستخدم لفترة محدودة بهدف تنفيذ مهام محددة، ويتم إلغاؤها تلقائياً بانتهاء المدة.
- 3.7 الحساب الخارجي (External Account): حساب يُمنح لطرف لا يتبع للهيكل التنظيمي للشركة (مثل شركة تأمين أو مزود خدمة)، ويتم التحكم به وفق اتفاقية دخول.
- 3.8 مبدأ أقل صلاحية (Least Privilege): مبدأ أمني يقضي بمنح المستخدمين الحد الأدنى من الصلاحيات اللازمة فقط لأداء مهامهم.
- 3.9 فصل المهام (Segregation of Duties): ضوابط رقابي يقضي بعدم منح شخص واحد صلاحيات متضاربة قد تؤدي إلى استغلال الصلاحية، مثل التنفيذ والموافقة في نفس النظام.
- 3.10 الحساب الإداري (Privileged Account): حساب يمنح صلاحيات متقدمة مثل إنشاء مستخدمين أو إدارة النظام ويخضع لرقابة مشددة.
- 3.11 Break Glass Account: حساب يُستخدم فقط في حالات الطوارئ القصوى ويتم تفعيله يدوياً مع تسجيل وتوثيق كامل.
- 3.12 سجل الوصول (Access Log): سجل إلكتروني يُوثق كل محاولات الدخول الناجحة أو الفاشلة، والتعديلات التي تتم على الحسابات والصلاحيات.
- 3.13 سجل التعديلات (Access Change Log): سجل مفصل يحتوي على كل العمليات التي يتم فيها منح، تعديل، أو إلغاء الصلاحيات، مع تحديد السبب والتاريخ والمسؤول المنفذ.
- 3.15 نظام MDM: اختصار لـ Mobile Device Management، وهو نظام لإدارة ومراقبة الأجهزة المحمولة التي تصل إلى أنظمة الشركة.
- 3.16 مراجعة الامتثال (Compliance Review): عملية تدقيق دورية للتحقق من مدى التزام المستخدمين بتطبيق سياسة إدارة الوصول ومعالجة المخالفات.

4. نطاق تطبيق السياسة:

4.1 تُطبق هذه السياسة على تنطبق هذه السياسة على جميع أنظمة وتقنيات الشركة، بما في ذلك: أنظمة علاقات العملاء (CRM)، أنظمة الموارد البشرية، بوابات شركات التأمين، أنظمة إصدار الوثائق، البريد الإلكتروني، والأنظمة المرتبطة بالجهات الرقابية مثل مؤسسة النقد وهيئة التأمين.

5. القطاعات والإدارات ذات العلاقة:

5.1 إدارة تقنية المعلومات. قسم الأمن السيبراني.

6. الكيانات ذات العلاقة:

6.1 كافة الكيانات المملوكة بالكامل إلى شركة داييموند.

6.2 المزودون التقنيون المعتمدون.

6.3 الجهات الرقابية (هيئة التأمين، هيئة الأمن السيبراني)



إدارة الجودة والتطوير Quality & Development Management

7. قواعد عامة:

7.1 إنشاء الحسابات وإدارة صلاحيات الدخول:

- 7.1.1 يجب على إدارة تقنية المعلومات إنشاء الحسابات الإلكترونية الرسمية فقط بناءً على طلب معتمد من الإدارة المالكة للنظام، متضمناً اسم المستخدم، القسم، نوع الصلاحية، ومدة الصلاحية إن وجدت.
- 7.1.2 يُلزم بعدم إنشاء أو تفعيل أي حساب بدون تحقق من وجود حاجة تشغيلية فعلية وموافقة الجهة المالكة للنظام.
- 7.1.3 يجب تسجيل كافة الحسابات ضمن سجل إدارة الوصول الإلكتروني، ويُحدث هذا السجل بشكل فوري عند كل عملية إضافة أو تعديل.
- 7.1.4 يُلزم بتوثيق الحسابات التقنية غير المرتبطة بالأفراد (مثل: API / Integration Accounts) وربطها بخدمة محددة، ولا تُفعل إلا بموافقة من مدير تقنية المعلومات ومسؤول الأمن السيبراني.

7.2 مراجعة الصلاحيات:

- 7.2.1 يجب مراجعة كافة صلاحيات الدخول على الأنظمة بشكل ربع سنوي من قبل مشرف تقنية المعلومات، وبمصادقة الجهة المالكة للنظام. يُلزم بإلغاء الصلاحيات غير النشطة أو غير المستخدمة لمدة تزيد عن 60 يوماً.
- 7.2.2 في حال انتهاء العلاقة الوظيفية أو الانتقال الداخلي، يجب تعطيل جميع الحسابات فوراً خلال 4 ساعات كحد أقصى.
- 7.2.3 تُراجع صلاحيات الحسابات المؤقتة يومياً ويُبلغ أي وصول انتهت مدته تلقائياً.

7.3 دورة حياة الوصول:

- 7.3.1 يجب اتباع دورة حياة متكاملة لإدارة الوصول تشمل: التهيئة ← المراقبة ← الإلغاء.
- 7.3.2 يُلزم توثيق كل مرحلة من الدورة في سجل الوصول المعتمد، وتحديد المسؤول المنفذ والتاريخ.
- 7.3.3 يجب تحديد آلية إدارة طلبات الوصول العاجلة خارج أوقات العمل وتوثيقها بأثر رجعي في أول يوم عمل يلي الطلب.

7.4 التحكم في مستويات الوصول:

- 7.4.1 يجب تطبيق مبدأ أقل صلاحية (Least Privilege) في منح الصلاحيات لجميع المستخدمين.
- 7.4.2 تُحدد مستويات الوصول حسب الوظيفة، ويُمنع منح صلاحيات إدارية ما لم تقتضي الحاجة التشغيلية وتوثق بمبررات.
- 7.4.3 يُمنع استخدام حسابات إدارية عامة أو غير مخصصة باسم المستخدم الرسمي.
- 7.4.4 يجب تطبيق مبدأ فصل المهام (Segregation of Duties) عند توزيع الصلاحيات بحيث لا يُمنح المستخدم صلاحية تنفيذ ومراجعة أو اعتماد في نفس النظام دون رقابة مزدوجة.
- 7.4.5 لا يُسمح باستخدام أجهزة شخصية للوصول إلى الأنظمة إلا بعد تسجيلها وتفعيل رقابة MDM عليها وموافقة الأمن السيبراني.
- 7.4.6 لا تُمنح الصلاحيات إلا بموافقة مكتوبة من مشرف تقنية المعلومات وتوثيق اتفاقية دخول إلكترونية.
- 7.4.7 تُربط الصلاحيات بتاريخ انتهاء تلقائي وتعليق تلقائي بعد انقضاء المهلة المحددة.

7.5 التوثيق والمراقبة:

- 7.5.1 يجب تسجيل جميع محاولات الدخول، الناجحة والفاشلة، ومراجعتها يومياً باستخدام منصة SIEM.
- 7.5.2 يُحتفظ بسجلات الدخول لمدة لا تقل عن 12 شهراً لأغراض التدقيق والتحقيق في الحوادث.
- 7.5.3 تُعد تقارير امتثال شهرية وتُرفع إلى لجنة الأمن السيبراني DIB Information Security Committee.
- 7.5.4 في حال رصد دخول غير اعتيادي (مثل دخول ليلى، أو من IP غير معروف)، يجب تنبيه مسؤول الأمن السيبراني خلال ساعة واحدة وفتح تحقيق فوري.
- 7.5.5 يجب إنشاء سجل خاص لتعديلات الصلاحيات (Access Change Log) يتضمن: اسم المستخدم، الجهة الطالبة، نوع التعديل، السبب، اسم منفذ التعديل، وتاريخ التنفيذ.
- 7.5.6 عند رصد دخول غير اعتيادي منخفض الشدة (مثل تسجيل دخول من موقع غير معتاد دون اختراق)، يجب تنفيذ إجراءات تحقق إضافية مثل إعادة المصادقة، ومراقبة نشاط الحساب لمدة لا تقل عن 72 ساعة.

7.6 المصادقة والتوثيق:

- 7.6.1 يجب تفعيل المصادقة متعددة العوامل (MFA) لجميع الأنظمة التي تحتوي على معلومات سرية أو بيانات حساسة.
- 7.6.2 يُمنع مشاركة بيانات الدخول أو استخدام حسابات مشتركة بين أكثر من موظف.
- 7.6.3 تُستخدم كلمات مرور قوية وفق معيار الشركة ويجب تغييرها كل 90 يوماً.
- 7.6.4 يجب أن يتم الوصول عن بُعد عبر VPN مؤمن فقط، ويُمنع استخدام أدوات تحكم عن بُعد غير مصرح بها.

7.7 إنهاء الوصول:

7.7.1 يُلزم بإلغاء صلاحيات الدخول مباشرةً في الحالات التالية:

7.7.1.1 انتهاء العلاقة الوظيفية

7.7.1.2 النقل الداخلي إلى قسم غير معني بالنظام

7.7.1.3 الإجازات الطويلة (أكثر من 30 يومًا)

7.7.2 يُمنع تعليق الحسابات دون إجراء حذف أو تعطيل فعلي.

7.8 إدارة الوصول للأنظمة السحابية:

7.8.1 يجب أن تخضع تطبيقات SaaS ونظم الحوسبة السحابية لنفس معايير إدارة الوصول الداخلية.

7.8.2 يُلزم بتوثيق الدخول عبر بروتوكولات آمنة (مثل SAML, OAuth).

7.8.3 يُمنع استخدام الحسابات الافتراضية التي يمنحها مزود الخدمة دون تقييد وتوثيق رسمي.

7.8.4 يُمنع استخدام الحسابات الافتراضية التي يمنحها مزود الخدمة إلا بعد ربطها بالمستخدم الفعلي وتسجيل صلاحياتها ضمن

سجل إدارة الوصول.

7.9 صلاحيات الطوارئ:

7.9.1 يجب إنشاء حسابات صلاحيات طارئة (Break Glass) مخصصة تستخدم فقط في حالات الطوارئ القصوى.

7.9.2 يُشترط موافقة مكتوبة من مدير الأمن السيبراني لتفعيل الحساب.

7.9.3 تُلغى الصلاحيات مباشرة بعد الاستخدام، وتُعد تقرير مفصل يُراجع من لجنة الأمن السيبراني.

7.10 التدريب والوعي:

7.10.1 يُلزم جميع الموظفين بحضور دورة توعوية ربع سنوية حول ضوابط إدارة الوصول.

7.10.2 يجب تدريب الموظفين الجدد على سياسات الوصول خلال أول أسبوع عمل.

7.11 الامتثال والمساءلة:

7.11.1 تُراقب الامتثال عبر تقارير شهرية من مشرف تقنية المعلومات ومسؤول الأمن السيبراني.

7.11.2 تُرفع التقارير إلى اللجنة الأمنية العليا لمراجعة المخالفات.

7.11.3 يُحاسَب أي موظف يتسبب في خرق لضوابط الوصول وفقًا للوائح الموارد البشرية والسياسات التأديبية.

7.11.4 يجب قياس الالتزام بتطبيق هذه السياسة من خلال تدقيق ربع سنوي، ويُعد تقرير تفصيلي بالنتائج والإجراءات

التصحيحية.

7.11.5 يُلزم أي مستخدم خارجي من شركات التأمين أو الموردين بالخضوع لكافة الضوابط الواردة في هذه السياسة، ويُسجل حسابه

كمستخدم مؤقت محدود الصلاحيات بموجب اتفاقية دخول معتمدة.

8. مسؤولية السياسة:

8.1 مشرف تقنية المعلومات

8.1.1 مسؤول عن تفعيل هذه السياسة، والإشراف على إدارة الحسابات والصلاحيات، وضمان حفظ السجلات.

8.2 مسؤول الأمن السيبراني:

8.2.1 مسؤول عن مراقبة الالتزام، مراجعة التعديلات، والتحقيق في أي دخول مشبوه أو غير اعتيادي.

8.3 إحصائي تقنية المعلومات:

8.3.1 مسؤول عن تنفيذ التعديلات الفنية، وتوثيق عمليات الدخول، ومراجعة الحسابات.

8.4 الإدارة المالكة للنظام:

8.4.1 مسؤولة عن الموافقة على طلبات الوصول وتحديد نوع الصلاحية.

8.5 المستخدم:

8.5.1 مسؤول عن استخدام صلاحياته فقط في إطار ما هو مصرح به، والإبلاغ عن أي دخول غير معتاد أو استخدام خاطئ.

8.6 مسؤول الأمن السيبراني:

8.6.1 مسؤول عن تفعيل أنظمة المراقبة، التنوع، التحقيق في الحوادث الأمنية، وضمان الامتثال الكامل للسياسة، ورفع تقارير دورية للإدارة العليا.

8.7 إدارة الالتزام والامتثال:

8.7.1 مسؤولون عن مراجعة مدى التزام الإدارات المختلفة بتطبيق الضوابط الأمنية على مستوى المستخدمين.

8.7.2 مسؤولون عن التحقق من وجود آلية فعالة للإبلاغ عن الحوادث التقنية والرد عليها بما يتوافق مع متطلبات الجهات الرقابية.

8.8 إدارة الجودة والتطوير:

8.8.1 مسؤولون عن التأكد من تطبيق هذه السياسات من خلال التدقيق والمراجعة الدورية.

9. التعاميم والتعليمات ذات العلاقة:

9.1 الجاقاً لتعميم المواصفات الفنية لنظام المراقبة التلفزيونية، الصادرة عن البنك المركزي السعودي (SAMA)، برقم (197/2020)، بتاريخ 27/10/2020.

9.2 استخدام نظام المراقبة الرقمي في النقل والحفظ الأمن لتسجيلات وبيانات أجهزة المراقبة التلفزيونية، الصادرة عن البنك المركزي السعودي (SAMA)، برقم (224/2021)، بتاريخ 24/10/2021.

9.3 التأكيد على الالتزام بالتعليمات الخاصة بحماية البيانات الشخصية للعملاء، الصادرة عن البنك المركزي السعودي (SAMA)، برقم (44043873)، بتاريخ 18/12/2024.

9.4 أي تعاميم تخص السياسة من الجهات المشرعة.

10. حفظ السياسة:

10.1 تحفظ النسخة الإلكترونية الغير قابلة للنسخ من السياسة المعتمدة على نظام الموارد البشرية ويطلع عليها الإدارات ذات العلاقة.

10.2 تحفظ النسخة الورقية من السياسة المعتمدة في إدارة الجودة والتطوير حسب المدة النظامية المحددة في كتيب تقاؤم المستندات ترحل نظامياً إلى حفظ المستندات.

11. مخالفة السياسة:

11.1 يُطبق في حق المخالف لهذه السياسة ماورد في لائحة جزاءات شركة داييموند المعتمدة.